Implementation Plan — Leish! Aesthetic Marketplace

Document	06 — Implementation Plan
Version	1.0
Date	2026-10-08
Companion	01-prd.md · 02-trd.md · 03-app-flow.md · 04-design-brief.md · 05-background-scheme.md

---

0. Guiding Strategy

The product is feature-rich but **its core funnel is broken in three independent ways** (booking validation, auth headers, ephemeral storage). The plan front-loads correctness, then unlocks the already-built AI surfaces, then hardens for launch.

```
Phase 0  STOP THE BLEEDING     booking works · auth writes work · errors visible
Phase 1  MAKE IT TRUSTWORTHY    authz · persistence · locale · secrets · tests/CI
Phase 2  UNLOCK WHAT'S BUILT    mount/remove orphan AI studios · routing · perf
Phase 3  POLISH & LAUNCH        background-scheme migration · a11y · content truth
Phase 4  GROW                   analytics · SEO ·Workspace · payments discovery
```

Estimate unit: engineer-days (single full-stack engineer unless noted). Totals are nominal, not padded.

Phase 0 — Stop the Bleeding (P0 · ~4 days · ship immediately)

Goal: a guest can complete a booking, and a provider/client can actually manage it.

#	Task
0.1	**Fix booking date regex** `^\d{4}-\d{2}-\d{2}RM` → `^\d{4}-\d{2}-\d{2}$`
0.2	**Surface booking errors** — replace `catch { console.error }` with inline banner + retry; show success confir
0.3	**Fix markdown-fence stripping** `/\s*```RM/` → strip trailing ``` fences
0.4	**Fix ID template literals** (3 sites): `${Math.random()}.toString(36)...}` → `${Math.random().toString(36).slice(2,8)}`
0.5	**Audit whole `server.ts` for the same corruption signature** (} replacing .)
0.6	**Add `Authorization` to all authenticated writes** — route through `src/lib/api.ts`
0.7	**Per-call error + success feedback** on those mutations (toast or inline), no silent failure
0.8	**Regression test** for the booking funnel: supertest happy path + 400 + 401
0.9	**Manual E2E pass** of the two core journeys (§Flow 4 & 9)
0.10	Hotfix deploy + smoke test

Exit criteria: core funnel works end-to-end in production; zero silent failures on user-facing writes.

Phase 0 status (2026-10-08)

#	Item	Status
0.1	Booking date regex	[OK] fixed (commit `412036d`)
0.2	Visible booking errors (`submitError` banner + `getValues` crash fix)	[OK] fixed (`412036d`)
0.3	Markdown-fence stripping → `stripJsonFences()`	[OK] fixed + test-covered
0.4	ID template literals (3 sites)	[OK] fixed — verified live: `book-1791395804519`
0.5	Corruption audit across repo	[OK] exactly 7 sites, all in `server.ts`, all fixe
0.6	`Authorization` on authenticated writes	[OK] all 6 call sites via `lib/api.ts`; PATCH v
0.7	Per-call error/success feedback	[OK] wired to existing `error` banners in Cli
0.8	Regression suite	[OK] `server.test.ts` — 17 tests green (`npm te`
0.9	Manual E2E, both journeys	[OK] desktop viewport — see findings be
0.10	Hotfix deploy + smoke	[OK] deployed `leish-google-qst5z7p2t` → **http**

Production smoke (2026-10-08): `GET /` 200 · `GET /api/salons` 200 · login 200 + JWT · `POST /api/bookings` with `YYYY-MM-DD` → **201** (id `book-1791397522763-j4ul3l`) · malformed date → 400 · `PATCH …/status` unauthenticated → **401** · same PATCH with JWT → **200** `confirmed`. Phase 0 is **complete**; proceed to Phase 1.

Roadmap execution status (2026-10-09)

The autonomous implementation pass completed the repository-safe portions of Phases 1–4:

- **Phase 1:** authorization hardening, production JWT validation, atomic protected JSON persistence, legacy password migration, API regression coverage, and CI/build gates are implemented.
- **Phase 2:** URL-backed navigation, browser history support, lazy-loaded AI studios, Vercel deep-link fallback, and centralized application API calls are implemented.
- **Phase 3:** accessible status/error states, keyboard focus treatment, reduced-motion support, responsive safeguards, and a deployment runbook are implemented.
- **Phase 4:** privacy-safe analytics hooks and runtime/static SEO/structured-data foundations are implemented.

The following items remain explicitly blocked or require product/cloud credentials and should not be represented as complete: production Firestore deployment verification, production geocoding/distance-matrix integration, consent-backed analytics delivery, server-rendered listing metadata, payments, real availability, Workspace write flows, and full visual/a11y audit at physical device widths. The Firestore adapter now passes the local emulator suite; the JSON backend remains the safe development fallback until authenticated cloud verification and deployment policy are supplied.

Follow-up polish (2026-10-09): Background rungs and reusable panel/scrim/glow utilities now exist in `src/index.css`; the Explore hero, Lookbook banner, and discovery cards use them. Listing cards are keyboard operable and defer below-the-fold imagery, Lookbook generation has visible retry feedback, and customer-facing prices on the catalog/map/advisor/portals use RM. Listing structured data includes `BeautySalon` service offers in MYR. See 07-launch-runbook.md for the deployment checklist, smoke pass, rollback, and JWT rotation procedure. The remaining raw arbitrary colors throughout other screens and physical-viewport visual/a11y validation still require a separate screen-by-screen pass; no production deploy or rollback rehearsal is claimed here.

Two additional defects found during E2E and fixed (not in the original audit):

- **§9.10 plaintext passwords** — the persisted `db_store.json` predates bcrypt, so *every* login 401'd against the real store. Fixed with `DataStore.normalizePasswords()` (re-hash on load) + migration test. **Requires a server restart to take effect on existing stores.**
- **§9.11 booking date off-by-one** — UTC vs. local mismatch stored the previous day's date for bookings made 00:00–08:00 GMT+8. Fixed with local date-part formatting.

Journey results: ① guest browse → detail → 3-step booking → `POST /api/bookings` **201**, confirmation with well-formed receipt, no error banner. ② provider demo login **200** → Salon Portal → Accept → `PATCH …/status` **200** with JWT → status `CONFIRMED` in UI.

E2E environment note: automated browser runs need a *visible* tab — with the document `visibilityState: 'hidden'`, `requestAnimationFrame` never fires, so `AnimatePresence mode="wait"` never completes its exit handshake and multi-step flows stall on step 1 (an environment artifact, not an app defect). For CI, run Playwright headed or with `prefers-reduced-motion` + a transition-free config.

Phase 1 — Make It Trustworthy (P0/P1 · ~12 days)

1A · Security & Authorization (~4 days)

#	Task
1.1	**Ownership middleware** (`requireSalonOwner`, `requireBookingAccess`) implementing TR-7; apply to `PUT /salons/:id`, s
1.2	**Lock down reads:** `GET /bookings` requires JWT and scopes by `email`/`salonId`; `GET /auth/demo-accounts` returns only
1.3	**Gate review creation:** require auth + a completed booking for that email
1.4	`JWT_SECRET` **fail-fast** when `NODE_ENV=production` and unset (TR-9); remove dev fallback
1.5	**Rotate & de-commit secrets:** Firebase web key, Maps key in `InteractiveMap.tsx:37` + `.env.example`; move Ma
1.6	**Rate-limit buckets** (`auth` / `read` / `ai`) (TR-8); re-enable Helmet CSP in production
1.7	**Demo password handling:** show demo credentials only via a build-time constant, never list real users

1B · Data Durability (~4 days)

#	Task
1.8.1	Define a `DataStore` **interface** matching current usage; keep JSON impl as the test/dev fallback (TR-2)
1.8.2	**Firestore implementation** using Firebase Admin SDK; collections `salons`, `bookings`, `reviews`, `users` per `fireba`
1.8.3	**Idempotent seed/migration:** run only when empty; never destructive re-seed on existing data
1.8.4	Client reads for catalog via API (unchanged) — Firestore stays server-side only; keep deny-by-default ru
1.8.5	Booked-indexes + query plan: `bookings.byEmail`, `bookings.bySalon`, `reviews.bySalon`
1.8.6	Remove `/tmp/db_store.json` path and the ”Firestore Live” decorative badge → real health indicator

1C · Locale, Content Truth & Config (~2 days)

#	Task
1.9	**Currency → RM everywhere:** map pins, travel fee, booking summary, JSON-LD (`index.html` USD → MYR)
1.10	**Distance → km;** replace hash-pseudo-distance with `google.maps.geometry` / Geocoding API distance matrix (
1.11	**Derive hero stats from data** (verified MUAs, ateliers counts)
1.12	**Remove decorative claims** (”Cloud SQL eligibility verified”) or back them with live checks
1.13	**Reconcile fonts:** load exactly the families `@theme` declares (or re-point tokens to loaded families); drop u
1.14	**Split rate-limit buckets + AI timeout contract** (TR-3): `{source, data}` envelope on all `/gemini/*`

1D · Quality Gates (~2 days)

#	Task	Ac
1.15	**API integration suite** (vitest + supertest): every endpoint, incl. the 401/403 matrix from 1.1–1.3	Co
1.16	**ESLint + Prettier** config; fix violations; rename package `react-example` → `leish-marketplace`	`npm`
1.17	**CI pipeline** (GitHub Actions or Vercel checks): typecheck → lint → tests → build (TR-12)	PR
1.18	**Playwright smoke:** guest book flow + provider confirm flow	Ru

Exit criteria: secure, durable, tested, locale-correct; deploy survives redeploy with data intact.

Phase 2 — Unlock What's Already Built (P1/P2 · ~9 days)

#	Task
2.1	**Decision gate:** mount or remove `ImageStudio`, `VeoVideoStudio`, `GeminiChatbot` (they're complete but unmounted
2.2a	*(if mounting)* add ”Studio” nav group + lazy routes; wire chatbot as a global assistant entry
2.2b	*(if removing)* delete components + unused `/gemini/generate-*` / `chat` endpoints and tests
2.3	**URL-backed routing** (TR-1): `/`, `/listing/:id`, `/lookbook`, `/advisor`, `/workspace`, `/bookings`, `/portal/:section`; migrate th
2.4	**Code-splitting:** `React.lazy` per route, vendor chunk splitting; target initial JS < 350 KB gzip
2.5	**Single HTTP client** (TR-4): typed `api.ts` generated from shared zod schemas; delete raw `fetch` remnants
2.6	**Adopt or delete orphans** (TR-6): `design-tokens.ts` (regenerate from `@theme` or remove), `forms.ts` (adopt as s
2.7	**Hero-image state unification** (TR-5): one source (store + persist)
2.8	**Search debounce + query polish** (`placeholderData`, empty states)
2.9	**Workspace token persistence:** refresh-token rotation or explicit re-auth UX

Exit criteria: every built feature is reachable or deliberately cut; app is fast, shareable, and type-safe end-to-end.

Phase 3 — Polish & Launch (P1 · ~7 days)

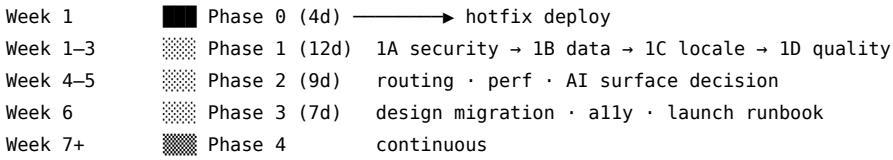
#	Task
3.1	**Background-scheme migration** (doc 05 §8): add rung tokens + utilities (`bg-panel-gradient`, `bg-scrim-*`, `glow-`
3.2	**Contrast + a11y pass:** re-verify gold-tint panels, focus rings, `aria-*`, keyboard nav, `prefers-reduced-motion`
3.3	**Copy & voice pass** per design brief §10 (serif headlines, mono labels, RM, actionable errors)
3.4	**Imagery pass:** consistent aspect boxes, `loading="lazy"`, warm-grade consistency, alt text
3.5	**Responsive QA:** 360 / 768 / 1280 across all 6 views + 3 modals
3.6	**Loading/empty/error states** finalized (doc 03 §11), skeletons for grids & AI
3.7	**Launch runbook:** env vars checklist, `JWT_SECRET` rotation, seed data, rollback plan, monitoring (Vercel logs

Exit criteria: PRD §12 Release Criteria all green.

Phase 4 — Grow (P2/P3 · backlog, unscheduled)

- **Analytics & funnel instrumentation** (search → detail → booking → confirm; AI fallback rate) to measure PRD §7.
- **SEO:** per-listing routes (2.3) + Server-rendered meta/OG for listing pages; Schema.org `BeautySalon`/`Service` with correct `priceCurrency: MYR`.
- **Verification badges** (manual ops flow) and admin surface (`role: admin`).
- **Google Workspace hub hardening** (P2/P3 features: Docs/Forms/Tasks write flows, appointment confirmation emails via Gmail).
- **Real availability:** time-slot grid from `workingHours` + existing bookings (currently free-text time).
- **Payments/deposits discovery** (v2 scoping — requires ledger, KYC, cancellation policy).
- **Reviews trust:** photo reviews, provider responses, abuse reporting.
- **PWA/offline shell** for mobile-first Klang Valley audience.

Timeline



Phase	Days	Cumulative
0 — Stop the bleeding	4	4
1 — Trustworthy	12	16
2 — Unlock built features	9	25
3 — Polish & launch	7	32
v1 total	**32 eng-days**	≈ 6.5 calendar weeks (1 engineer) · ~3.5 weeks (2 engineers)

Milestones & Gates

Milestone	Gate	Date target
M0 · Funnel fixed	Phase 0 exit + hotfix deployed	Week 1
M1 · Secure & durable	Phase 1 exit: authz matrix green, data survives redeploy, CI live	Week 3
M2 · Feature-complete	Phase 2 exit: routing + perf + AI-surface decision shipped	Week 5
M3 · v1 launch	PRD §12 release criteria all checked	Week 6–7
M4 · Measure	Analytics live, first funnel report	Week 9

Risks & Mitigations (plan-level)

Risk	Impact	Mitigation
Firestore migration slips → Phase 1 blocked	Data durability	DataStore interfa
Mounting the 3 orphan studios expands scope	Schedule	Decision gate 2.1
Single engineer, 32 days	Timeline	Phase 0 + 1D are
Concurrent edits to `server.ts` (bad-replace corruption pattern already seen)	Regressions	Phase 0.5 audit +
Secrets rotation breaks live integrations	Downtime	Rotate Maps/Fireb
Design migration (3.1) introduces visual regressions	Quality	Per-screen visual

---

Definition of Done (per task)

1. Code merged with green CI (typecheck + lint + tests + build).
2. Acceptance criteria from the task table verified.
3. No new raw hex / raw fetch / silent `catch` introduced (grep gates).
4. UI change reviewed at 360px and 1280px; keyboard reachable.
5. Errors surface to the user; AI paths label fallback output.
6. Docs updated if behavior or contract changed (PRD/TRD/Flow).